PRELIMINARY SECURITY ASSESSMENT

test 2

test

TARGET SYSTEM	127.0.0.1
ASSESSED BY	SCOPE Automated Engine
ASSESSMENT DATE	2026-03-21
CLASSIFICATION	Internal Use Only
REPORT ID	SCOPE-7

Table of Contents

1 Executive Summary

2 Scope & Methodology

3 System Overview

4 Findings
- Critical (3)
- High (2)
- Medium (6)
- Low (4)

5 Assessment Coverage

6 Recommendations

7 Disclaimer

1 Executive Summary

test

3	2	6	4	0
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

A total of **16 findings** were identified during this assessment. **3 critical findings** require immediate attention.

2 Scope & Methodology

Assessment Scope

The assessment covered the system configuration, installed packages, running services, network exposure, user accounts, file permissions, and security hardening baseline of the target system.

Methodology

SCOPE performed a non-intrusive, read-only audit of local system state. No exploits or active probes were used. All data was collected via OS-native interfaces and configuration files. The assessment was conducted without causing any disruption to system availability.

3 System Overview

System information was not collected during this assessment.

4 Findings

Finding Index

#	ID	TITLE	SEVERITY	CATEGORY
1	F-0039	No active host-based firewall detected	CRITICAL	Network
2	F-0045	SSH permits direct root login	CRITICAL	Authentication
3	F-0053	World-readable files containing hardcoded credentials	CRITICAL	Secrets
4	F-0044	Unexpected SUID/SGID binaries detected	HIGH	File Permissions
5	F-0046	SSH password authentication enabled	HIGH	Authentication
6	F-0038	Listening port inventory (16 port(s) detected)	INFO	Network
7	F-0042	Martian packet logging disabled	LOW	System Hardening
8	F-0049	SSH login banner not configured	LOW	Configuration
9	F-0050	SSH agent forwarding enabled	LOW	Configuration
10	F-0052	CUPS print service is running	LOW	Services
11	F-0040	Kernel pointer exposure not restricted	MEDIUM	System Hardening
12	F-0041	ICMP redirect sending enabled	MEDIUM	System Hardening
13	F-0043	IP forwarding enabled	MEDIUM	System Hardening
14	F-0047	SSH MaxAuthTries is too high	MEDIUM	Configuration
15	F-0048	SSH has no idle session timeout	MEDIUM	Configuration
16	F-0051	No password complexity policy configured in PAM	MEDIUM	Authentication

CRITICAL Findings (3)

F-0039 No active host-based firewall detected — CRITICAL

DESCRIPTION

No host-based firewall is active. All listening services are directly reachable from the network without any filtering. A firewall provides a critical layer of defence-in-depth.

CATEGORY

Network

EVIDENCE

```
ufw:
iptables: no rules beyond defaults (0 non-default rules)
nftables: no ruleset (0 lines)
```

REMEDIATION

Enable ufw (simplest) or configure iptables/nftables rules.

F-0045 SSH permits direct root login

CRITICAL

DESCRIPTION

PermitRootLogin is set to 'yes' or not restricted. Direct root SSH access bypasses audit trails and reduces the work an attacker needs to do after gaining SSH access.

CATEGORY

Authentication

EVIDENCE

```
/etc/ssh/sshd_config — PermitRootLogin yes
```

REMEDIATION

Disable direct root login. Use a normal user account with sudo.

F-0053 World-readable files containing hardcoded credentials

CRITICAL

DESCRIPTION

Files that appear to contain credentials or secrets are world-readable. Any local user on this system can read these files and extract credentials.

CATEGORY

Secrets

EVIDENCE

```
/home/omni/.cache/yay/java24-openjdk/src/jdk24u-jdk-24.0.2-12/src/
jdk.management.agent/share/conf/management.properties  [world-readable]
  line 110: #          javax.net.ssl.keyStorePassword=[REDACTED]
  line 112: #          javax.net.ssl.trustStorePassword=[REDACTED]
/home/omni/Downloads/Phishly/docker-compose.yml  [world-readable]
  line 16:       POSTGRES_PASSWORD: [REDACTED]
  line 139:       POSTGRES_PASSWORD: [REDACTED]
  line 146:       SMTP_PASSWORD: [REDACTED]
/home/omni/Downloads/Phishly/db/docker-compose.yml  [world-readable]
  line 10:       POSTGRES_PASSWORD: [REDACTED]
/home/omni/Downloads/Phishly/webadmin/docker-compose.yml  [world-readable]
  line 49:   #     POSTGRES_PASSWORD: [REDACTED]
/home/omni/Downloads/Phishly/worker/docker-compose.yml  [world-readable]
  line 21:       POSTGRES_PASSWORD: [REDACTED]
  line 28:       SMTP_PASSWORD: [REDACTED]
/home/omni/yay/src/yay-12.5.7/.github/workflows/builder-image.yml  [world-
readable]
  line 39:           password: [REDACTED]
  line 94:           password: [REDACTED]
/home/omni/yay/src/yay-12.5.7/.github/workflows/multiarch-build.yml
[world-readable]
  line 31:           password: [REDACTED]
/home/omni/yay/src/yay-12.5.7/.github/workflows/testing-git.yml  [world-
readable]
  line 34:           echo 'github ALL=[REDACTED]
/home/omni/yay/src/gopath/pkg/mod/github.com/!jguer/go-alpm/
v2@v2.3.1/.github/workflows/builder-image.yml  [world-readable]
  line 21:           password: [REDACTED]
/home/omni/yay/src/gopath/pkg/mod/github.com/!jguer/go-alpm/
v2@v2.3.1/.github/workflows/test-git.yml  [world-readable]
  line 26:                 echo "github ALL=[REDACTED]
/home/omni/yay/src/gopath/pkg/mod/github.com/itchyny/
gojq@v0.12.18/.github/workflows/ci.yaml  [world-readable]
  line 108:           password: [REDACTED]
  line 115:           password: [REDACTED]
/home/omni/.winboat/docker-compose.yml  [world-readable]
  line 14:       PASSWORD: [REDACTED]
/opt/metasploit/.github/workflows/mssql_acceptance.yml  [world-readable]
  line 54:           MSSQL_SA_PASSWORD: [REDACTED]
/opt/metasploit/.github/workflows/mysql_acceptance.yml  [world-readable]
  line 54:           MYSQL_ROOT_PASSWORD: [REDACTED]
/opt/metasploit/.github/workflows/postgres_acceptance.yml  [world-
readable]
  line 57:           POSTGRES_PASSWORD: [REDACTED]
/opt/metasploit/.github/workflows/shared_gem_verify_rails.yml  [world-
readable]
  line 55:             -e POSTGRES_PASSWORD=[REDACTED]
/opt/metasploit/.github/workflows/shared_smb_acceptance.yml  [world-
readable]
  line 33:       SMB_PASSWORD: [REDACTED]
/opt/metasploit/.github/workflows/verify.yml  [world-readable]
  line 52:           POSTGRES_PASSWORD: [REDACTED]
/opt/metasploit/data/exploits/CVE-2025-8518/docker-compose.yml  [world-
```

```
readable]
  line 28:       MYSQL_ROOT_PASSWORD: [REDACTED]
  line 31:       MYSQL_PASSWORD: [REDACTED]
/opt/metasploit/data/jtr/dynamic.conf  [world-readable]
  line 487: Test=[REDACTED]
  line 807: Test=[REDACTED]
  line 892: Test=[REDACTED]
/opt/metasploit/data/snmp/mibs/L2TP-MIB.yaml  [world-readable]
  line 33: l2tpTunnelConfigSecret: [REDACTED]
  line 123: l2tpDomainConfigSecret: [REDACTED]
/opt/metasploit/data/snmp/mibs/PPP-SEC-MIB.yaml  [world-readable]
  line 6: pppSecuritySecretsSecret: [REDACTED]
/opt/metasploit/test/kubernetes/secrets/templates/basic-auth.yaml  [world-
readable]
  line 8:   password: [REDACTED]
/opt/metasploit/test/kubernetes/secrets/templates/opaque.yaml  [world-
readable]
  line 16:   password: [REDACTED]
/opt/metasploit/test/kubernetes/secrets/templates/ssh-auth.yaml  [world-
readable]
  line 11:   ssh-privatekey: [REDACTED]
```

REMEDIATION

Restrict file permissions and remove or rotate any exposed credentials.

HIGH Findings (2)

F-0044 Unexpected SUID/SGID binaries detected — HIGH

DESCRIPTION

Binaries with SUID or SGID bits set outside the expected set were found. SUID binaries run with the owner's privileges (often root). An unexpected SUID binary may be a backdoor or misconfiguration that enables privilege escalation.

CATEGORY

File Permissions

EVIDENCE

```
/bin/ksu  (SUID, mode: 0o4755)
/bin/chage  (SUID, mode: 0o4755)
/bin/expiry  (SUID, mode: 0o4755)
/bin/gpasswd  (SUID, mode: 0o4755)
/bin/groupmems  (SGID, mode: 0o2750)
/bin/passwd  (SUID, mode: 0o4755)
/bin/sg  (SUID, mode: 0o4755)
/bin/pkexec  (SUID, mode: 0o4755)
/bin/crontab  (SUID, mode: 0o4755)
/bin/chfn  (SUID, mode: 0o4755)
/bin/chsh  (SUID, mode: 0o4755)
/bin/newgrp  (SUID, mode: 0o4755)
/bin/wall  (SGID, mode: 0o2755)
/bin/write  (SGID, mode: 0o2755)
/bin/sudo  (SUID, mode: 0o4755)
/bin/fusermount  (SUID, mode: 0o4755)
/bin/unix_chkpwd  (SUID+SGID, mode: 0o6755)
/bin/mount.cifs  (SUID+SGID, mode: 0o6755)
/bin/fusermount3  (SUID, mode: 0o4755)
/sbin/ksu  (SUID, mode: 0o4755)
/usr/bin/ksu  (SUID, mode: 0o4755)
/usr/sbin/ksu  (SUID, mode: 0o4755)
/usr/lib/dbus-daemon-launch-helper  (SUID, mode: 0o4110)
```

REMEDIATION

Review each binary. Remove the SUID/SGID bit if it is not needed.

F-0046 SSH password authentication enabled — HIGH

DESCRIPTION

PasswordAuthentication is not disabled. Password-based SSH logins are vulnerable to brute-force and credential-stuffing attacks. Public-key authentication is significantly more secure.

CATEGORY

Authentication

EVIDENCE

```
/etc/ssh/sshd_config — PasswordAuthentication yes
```

REMEDIATION

Disable password auth and use SSH key pairs exclusively.

MEDIUM Findings (6)

F-0040 Kernel pointer exposure not restricted — MEDIUM

DESCRIPTION
kernel.kptr_restrict is 0. Kernel symbol addresses in /proc/kallsyms and similar interfaces are visible to unprivileged users, aiding kernel exploit development.

CATEGORY
System Hardening

EVIDENCE

```
kernel.kptr_restrict = 0  (expected: >= 1)
```

REMEDIATION
Set kernel.kptr_restrict to at least 1 (or 2 for maximum restriction).

F-0041 ICMP redirect sending enabled — MEDIUM

DESCRIPTION
The host will send ICMP redirect messages. This is only appropriate on routers. On servers and workstations it should be disabled.

CATEGORY
System Hardening

EVIDENCE

```
net.ipv4.conf.all.send_redirects = 1  (expected: 0)
```

REMEDIATION
Disable ICMP redirect sending: net.ipv4.conf.all.send_redirects = 0.

F-0043 IP forwarding enabled — MEDIUM

DESCRIPTION
IP forwarding is enabled. Unless this host is intentionally acting as a router or VPN gateway, forwarding should be disabled to prevent traffic pivoting.

CATEGORY
System Hardening

EVIDENCE

```
net.ipv4.ip_forward = 1  (expected: 0)
```

REMEDIATION
Disable IP forwarding unless this host is a router: net.ipv4.ip_forward = 0.

F-0047 SSH MaxAuthTries is too high — MEDIUM

DESCRIPTION
MaxAuthTries is set to 6. A high value allows more authentication attempts per connection, making brute-force attacks easier.

CATEGORY
Configuration

EVIDENCE

```
/etc/ssh/sshd_config — MaxAuthTries 6
```

REMEDIATION
Reduce MaxAuthTries to 3 or 4.

F-0048 SSH has no idle session timeout — MEDIUM

DESCRIPTION ClientAliveInterval is 0 (disabled). Idle SSH sessions are never terminated, leaving unattended sessions open indefinitely.

CATEGORY Configuration

EVIDENCE

```
/etc/ssh/sshd_config — ClientAliveInterval 0 (no timeout)
```

REMEDIATION Set an idle timeout to automatically disconnect inactive sessions.

F-0051 No password complexity policy configured in PAM — MEDIUM

DESCRIPTION Neither pam_pwquality nor pam_cracklib is configured in the PAM password stack. Without a complexity policy, users can set trivially weak passwords that are easy to brute-force.

CATEGORY Authentication

EVIDENCE

```
/etc/pam.d/system-auth — no pam_pwquality or pam_cracklib found
```

REMEDIATION Install and configure pam_pwquality to enforce password complexity.

LOW Findings (4)

F-0042 Martian packet logging disabled — LOW

DESCRIPTION Packets with impossible source addresses (martians) are not being logged. Enabling this aids in detecting IP spoofing and routing anomalies.

CATEGORY System Hardening

EVIDENCE

```
net.ipv4.conf.all.log_martians = 0  (expected: 1)
```

REMEDIATION Enable martian packet logging: net.ipv4.conf.all.log_martians = 1.

F-0049 SSH login banner not configured — LOW

DESCRIPTION No SSH warning banner is displayed to connecting users. A legal notice banner establishes that access is authorised only and provides a basis for prosecution.

CATEGORY Configuration

EVIDENCE

```
/etc/ssh/sshd_config — Banner not set
```

REMEDIATION Configure a legal warning banner shown before login.

F-0050 SSH agent forwarding enabled

LOW

DESCRIPTION

AllowAgentForwarding is enabled. If users forward their SSH agent to a compromised intermediate host, an attacker on that host can use the forwarded agent to authenticate to other systems.

CATEGORY

Configuration

EVIDENCE

```
/etc/ssh/sshd_config — AllowAgentForwarding yes
```

REMEDIATION

Disable agent forwarding unless specifically needed.

F-0052 CUPS print service is running

LOW

DESCRIPTION

CUPS (print service) is rarely needed on servers and has had historical RCE vulnerabilities. Disable if this host does not serve print jobs.

CATEGORY

Services

EVIDENCE

```
Running service(s): cups
```

REMEDIATION

Disable 'cups' if not explicitly required.

5 Assessment Coverage

- Listening port enumeration and dangerous service detection
- Host-based firewall status check (ufw, iptables, nftables)
- Kernel sysctl hardening parameter checks
- World-writable files and unexpected SUID/SGID binary scan
- User account and privilege review
- SSH daemon configuration audit
- PAM password quality and account lockout configuration check
- Package update status and EOL version detection
- Running service audit — dangerous and unnecessary service detection
- Hardcoded credential and secret file detection
- SSH private key and authorized_keys permission audit

6 Recommendations

No specific recommendations recorded. Review individual finding remediation guidance above.

Disclaimer

This report was generated automatically by the SCOPE platform based on data collected during the assessment window. Results reflect the system state at the time of assessment and may not account for changes made after that point. This report is intended for internal use by authorized personnel only. SCOPE does not guarantee the completeness or accuracy of findings and recommends manual verification of critical items before remediation.

Generated by **SCOPE** — Security Configuration Observation and Protection Engine — 2026-03-22 00:52 UTC